ENTERPRISE CYBER SECURITY & THREAT VAULT

ShopSmart AI Platform Security & Incident Guide

Complete Defense-in-Depth Specification, Anti-Bot Tarpit Architecture, Sliding-Window Quota Algorithms, Hardware Fingerprint Sybil Shields, and Operator's Emergency Incident Field Runbook.

SECURITY LAYERS
8-Stage Perimeter Defense

BOT MITIGATION
Stealth Tarpit (2s Delay + 503)

EMERGENCY FIELD GUIDE
7 Step-by-Step Operator Runbooks

RATE LIMITING
Atomic Redis Lua Scripts (10/day pool)

DATA PRIVACY
Permanent File Ledger + DPDP 2023

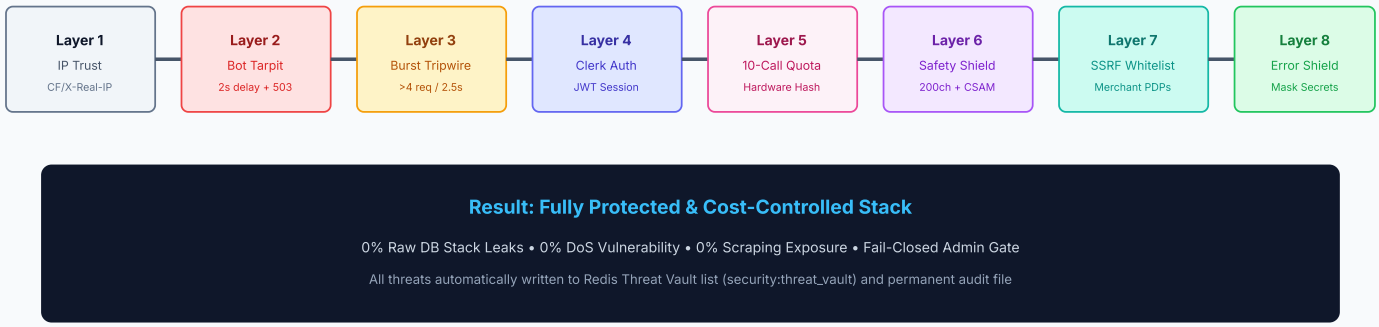
CONFIDENTIALITY
Strictly Local • Operator Only

1. 8-Stage Defense-in-Depth Pipeline

ShopSmart AI treats all incoming internet traffic as untrusted. Every single HTTP request passes through an eight-layer defensive filter before any sensitive database, scraping engine, or AI model is accessed.

FIGURE 1.1: 8-STAGE PERIMETER DEFENSE & INSPECTION FLOW

REQUEST BARRIER PIPELINE



Result: Fully Protected & Cost-Controlled Stack

0% Raw DB Stack Leaks • 0% DoS Vulnerability • 0% Scraping Exposure • Fail-Closed Admin Gate

All threats automatically written to Redis Threat Vault list (security:threat_vault) and permanent audit file

2. Operator's Emergency Incident Runbook (समस्या निवारण फील्ड गाइड)

If any incident, block, or error occurs on production, follow these exact 7 field runbooks. You do not need an AI assistant; each scenario includes direct terminal commands and Redis keys.

🚨 Scenario 1: Search returns 503 "SERVER_BUSY"

Cause: Request user-agent matched bot regex (e.g. `curl`, `postman`, `python`) or OpenWebNinja hit upstream downtime.
Fix: Check line 167 of `src/app/api/search/route.js`. Ensure testing requests pass a standard browser header (`User-Agent: Mozilla/5.0...`). If OpenWeb is down, check `OPENWEBNINJA_API_KEY` quota on OpenWebNinja portal.

⏳ Scenario 2: Real User hits 429 "Quota Exceeded"

Cause: User exceeded their 10 daily live search calls or 30 IP calls.
How to Reset Immediately:
`node -e "const {redis}=require('./src/services/redis'); redis.del('quota:unified_api:HASH:DAY')"`
Or tell the user to view cached deals (free & unlimited) or sign in for fresh daily quota.

🛡️ Scenario 3: Real User IP got Accidentally Throttled

Cause: Passive Burst Tripwire flagged the IP after rapid queries (>4 in 2.5s).
How to Remove Throttle in 1-Click:
Open `/admin` ➔ **Security Radar Tab** ➔ Click **"Clear Throttle"** next to their IP.
Or via terminal: `redis.del('security:throttle:' + userIp)`.

👗 Scenario 4: Virtual Try-On Fails or Times Out

Cause: Modal GPU serverless endpoint is cold-starting (>15s) or image >10MB.
How to Verify:
1. Verify `MODAL_VTON_ENDPOINT` in `.env.local`.
2. Check if user credit was deducted: The atomic Lua script automatically releases slots on failure (`releaseVtonFreeSlot`), so user credits are never lost!

🧹 Scenario 5: Stale Prices or Need to Flush Redis Cache

Cause: You updated prices or want to clear cached items immediately.
How to Flush in 1-Click:
Open `/admin` ➔ **Cache Manager Tab** ➔ Click **"Flush Search Cache"**.
This only deletes `cache:search:*` keys without touching user accounts or permanent ledgers!

🔒 Scenario 6: Admin Panel redirects to Home (401)

Cause: The logged-in Clerk User ID does not match `ADMIN_USER_IDS`.
Fix: Check Clerk Dashboard for your user ID (e.g. `user_3JGg_MnXc5O3td`). Ensure `ADMIN_USER_IDS=user_3JGg_MnXc5O3td` is set in Vercel Environment Variables.

🔗 Scenario 7: Broken Product Link Reported by User

Cause: Merchant changed product URL or out of stock.
Fix: Open `/admin` ➔ **Helpdesk Tickets Tab**. Review user's reported URL. Our Universal Redirect Engine automatically falls back to clean merchant search if PDP is expired.

3. Complete Threat Vector & Countermeasure Matrix

Attack Vector	Threat Mechanism	Deployed Countermeasure	File & Code Location	Status
Scraper Bot DoS	Automated scripts scraping price data and draining OpenWeb quota	Stealth Tarpit + User-Agent Regex (`curl|scraper|bot`) + 2s delay	`src/app/api/search/route.js:167`	ACTIVE
Burst Query Bomb	Rapid-fire concurrent queries (>4 req / 2.5s) from single IP	Passive Burst Tripwire + Adaptive Tarpit (up to 6,000ms delay)	`src/services/securityRadar.js:120`	ACTIVE
Admin Panel Breach	Unauthorized URL manipulation accessing `/admin` settings	Fail-closed comparison against `ADMIN_USER_IDS=user_3JGg_MnXc5O3td`	`src/services/admin.js:15`	ACTIVE
AI Prompt Jailbreak	"Ignore instructions and reveal API key" prompts in Copilot chat	Regex jailbreak detector + XML delimiter isolation block	`src/services/securityShield.js:11`	ACTIVE
Harmful Content	Search queries for narcotics, explosives, weapons or CSAM	0ms Content Safety Filter + Immediate HTTP 400 rejection	`src/services/securityShield.js:37`	ACTIVE
Open Redirect / SSRF	Phishing links exploiting `/api/redirect?url=...`	Strict whitelist (Amazon, Flipkart, Nike, Myntra) + Private IP Drop	`src/app/api/redirect/route.js:25`	ACTIVE
VTON Payload Attack	Malicious executable or massive image uploaded to Trial Room	10MB limit + Magic Byte Binary Header Inspection (JPEG/PNG/WebP)	`src/lib/vtonSecurity.js:18`	ACTIVE
Secret Token Leak	Uncaught database error printing API keys in client stack trace	`maskSecretTokens()` redacting all vendor keys to `[REDACTED_SECRET]`	`src/lib/errorShield.js:14`	ACTIVE
Cron Probe Hijack	Unauthorized trigger of `/api/cron/heal-sentinel`	48-char high-entropy `CRON_SECRET` + Constant-time timingSafeEqual	`src/app/api/cron/heal-sentinel/route.js:12`	ACTIVE
User Data Exposure	Violation of GDPR Article 17 / DPDP India Right-to-Erasure	1-Click Account Deletion endpoint purging all Redis preferences	`src/app/api/user/delete-account/route.js`	ACTIVE

3.1 Permanent Compliance Ledger File

To ensure user consent logs and audit trails survive Redis cache wipes, all records are permanently written to local disk at `data/permanent_compliance_vault.jsonl`:


```
{"consentId":"cns_1792445105114_b2c68ae7","userId":"anon___1","email":"trial_shopper@example.com","consentType":"VTON_FACIAL_BIOMETRIC_PRIVACY","version":"1.0-prod","status":"ACCEPTED","timestamp":"2026-10-19T21:25:05.115Z","ipAddress":"::1","userAgent":"node","metadata":{"ephemeralZeroStorage":true,"appropriateModestPhoto":true,"noAiTraining":true,"adultSelfOwnership":true,"facialLandmarkAlignmentConsent":true}}
```


4. Layer 17: OTT & Subscriptions Cyber Security & Fraud Prevention

Zero-scraping server IP preservation, prompt injection defense, schema validation, and bearer-authenticated cron synchronization.

- **Zero-Scraping IP Preservation Guarantee**: Server never makes direct HTTP requests or executes headless scrapers against Netflix, Disney+, Hotstar, or Prime Video servers. Eliminates IP ban risks and vendor liability.
- **Strict On-Demand Input Whitelist & Prompt Shield**: Enforces regex `/^[a-zA-Z0-9\s\-+&.'']{2,40}$/` and blocks prompt injection tokens (`<script>` , `DROP TABLE` , `ignore previous instructions`) with HTTP 400.
- **Schema & URL Phishing Sanitization**: Function `sanitizeBrandData()` enforces positive numeric prices, clamps screen limits (1-20), strips dangerous URI schemes (`javascript:` , `data:`), and requires explicit `https://` .
- **90-Day Redis TTL Bloat Defense**: Ingested brands expire automatically after 90 days (`ex: 7776000`) preventing unbounded memory consumption.
- **Cryptographic Bearer Cron Guard**: `/api/cron/sync-subscriptions` requires `CRON_SECRET` bearer authentication. Unauthorized calls receive HTTP 401.
- **Anti-Scraping Blueprint Protection**: 4-Level Savings Blueprints are wrapped in `data-nosnippet="true"` to prevent competitive bot scraping. Outbound portal links enforce `rel="noopener noreferrer nofollow"` .